

Security+ 5.2 · Risk Analysis

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.2 — Risk Analysis (9:13)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: Análise: qualitativa (alto/médio/baixo) vs quantitativa (\$ — $SLE \times ARO = ALE$); risk appetite (o que a organização ACEITA — board define); risk tolerance (variação aceitável por área); risk register.

Highlights que a prova cobra

- $ALE = SLE$ (perda por incidente) $\times$ ARO (vezes/ano) — o quantitativo
- Appetite: o RISCO que aceita; tolerance: variação por área (operacional)

Dicas de prova & Cenários Típicos

- 'accepting a specific risk level per business unit' = risk tolerance

Cenário clássico de exame: 'perda por incidente de \$500k $\times$ 2/ano = ALE de \$1M/ano' — quantitativo.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 5.2)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Risk Analysis) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Estratégias de Tratamento de Risco:**
 - **Mitigação/Redução:** aplicar controles técnicos ou administrativos para diminuir probabilidade ou impacto (ex: instalar EDR).
 - **Transferência/Compartilhamento:** repassar o impacto financeiro para um terceiro (ex: contratar seguro cibernético ou terceirizar para um MSSP).
 - **Aceitação:** reconhecer o risco quando o custo do controle supera o valor do ativo (exige aprovação formal da alta liderança).
 - **Evitação:** cancelar ou não iniciar a atividade arriscada (ex: descontinuar um serviço legado inseguro).
- **Métricas de Risco e Análise Quantitativa:**
 - **SLE (Single Loss Expectancy):** perda financeira estimada para uma única ocorrência do incidente ($\text{Asset Value} \times \text{Exposure Factor}$).
 - **ARO (Annualized Rate of Occurrence):** frequência anual estimada do evento.
 - **ALE (Annualized Loss Expectancy):** custo anualizado total do risco: $\text{ALE} = \text{SLE} \times \text{ARO}$.
- **Métricas de Continuidade de Negócios (BCP / DRP):**
 - **RTO (Recovery Time Objective):** tempo máximo tolerável que o sistema pode ficar inoperante após um desastre.
 - **RPO (Recovery Point Objective):** volume máximo de dados que a organização tolera perder, medido em tempo (ex: se o backup é diário, o RPO é de até 24 horas de transações perdidas).
 - **MTBF (Mean Time Between Failures):** tempo médio em que um equipamento opera sem falhas.
 - **MTTR (Mean Time to Repair):** tempo médio necessário para consertar ou substituir um componente com defeito.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Se a questão disser 'contratar apólice de seguro contra ataques cibernéticos' = **Transferência de Risco** (nunca mitigação).
- RPO define a frequência dos backups; RTO define a velocidade da infraestrutura de restauração e failover.

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. RTO (Recovery Time Objective) mede:

- A)** Quanto DADO você aceita perder
- B)** Quanto TEMPO o serviço pode ficar fora
- C)** O custo do incidente
- D)** O número de usuários afetados

2. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Appetite: o RISCO que aceita; tolerance: variação por área (operacional)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'accepting a specific risk level per business unit'=risk tolerance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo....

6. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Appetite: o RISCO que aceita; tolerance: variação por área (operacional)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)...

8. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'accepting a specific risk level per business unit'=risk tolerance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance...

9. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo...

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — Quanto TEMPO o serviço pode ficar fora.

✓ **Por que está certa:** RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder).

✗ **Por que as outras estão erradas:**

- *Quanto DADO você aceita perder:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *O custo do incidente:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *O número de usuários afetados:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) A — Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO$ (vezes/ano) — o quantitativo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) A — Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): Appetite: o RISCO que aceita; tolerance: variação por área (operacional).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: 'accepting a specific risk level per business unit' = risk tolerance....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 5.2 (Risk Analysis): 'accepting a specific risk level per business unit'=risk tolerance.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): Appetite: o RISCO que aceita; tolerance: variação por área

(operacional).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'accepting a specific risk level per business unit'=risk tolerance.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO$ (vezes/ano) — o quantitativo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.